Contents

Volume 02 — GRC & Contingency Planning **1**
Lecture T08: Security Management and GRC — Part 01 1
Lecture T09: Security Management and GRC — Part 02 3
Lecture T10: Security Management and GRC — Part 03 4
Lecture T11: Contingency Planning — Part 01 6
Lecture T12: Contingency Planning — Part 03 7
Lecture T13: Contingency Planning — Part 02 9
Lecture T14: Live session — Contingency planning Q&A 10

Volume 02 — GRC & Contingency Planning

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T08: Security Management and GRC — Part 01

Learning focus

- Place cybersecurity inside a **management** problem (cyber assets as resources), not only a technology problem.
- Name the three broad approaches to cybersecurity management that the instructor constructs: GRC, standards-driven, and textbook / organizational planning.
- Distinguish **governance** from **management**, and say what it means to attach cybersecurity to governance.
- Map the three GRC frameworks taught here: **COBIT**, **COSO**, and **COSO ERM**.
- List what **internal controls** try to control, and the three control types (preventive, detective, corrective).
- Sketch COBIT 5's split of governance vs management and the Plan–Build–Run–Monitor cycle.

Key terms

Term	Meaning in this lecture
GRC	Governance, Risk and Compliance — broad management/governance framework used in cybersecurity circles
ERM	Enterprise Risk Management — all organizational risk under one frame; cyber is one category
Governance	Higher body than management: institutes management, monitors organizational health, sets direction
Management	C-level and structures that make the organization function toward board-set strategy
COBIT	ISACA GRC standard; IT-based, enterprise end-to-end control (version 5 here)

Term	Meaning in this lecture
COSO	Committee of Sponsoring Organizations; accounting-origin **internal control** framework
COSO ERM	COSO expanded with response, objective setting, identification — risk-based enterprise frame
Internal control	Processes that safeguard assets, records, reporting, efficiency, policy adherence, legal compliance
Preventive / detective / corrective	Three aspects of how internal controls work
APO	COBIT process set associated with **Plan**
SOX	Sarbanes–Oxley — US accounting standard after major scandals

Frameworks / formulas

- **Three management approaches:** GRC (cyber inside ERM) · standards-driven (ISO/NIST on cyber) · textbook organizational planning (strategy + contingency).
- **Three GRC frameworks:** COBIT · COSO · COSO ERM.
- **Internal control types:** preventive, detective, corrective.
- **COBIT 5 management cycle:** Plan → Build → Run → Monitor; governance Direct / Evaluate / Monitor above that.
- **COSO ERM additions:** risk **response**, **objective setting**, **identification**.

Distinctions

- This course is **management of cyber assets**, not a technology course; technology is a constituent.
- **Governance ≠ management.** Governance is the higher body that installs and monitors management. Saying "cyber governance" means cyber is **strategic**, top priority.
- **GRC ≠ ISO/NIST.** GRC frameworks (COBIT/COSO/ERM) are **enterprise-wide**; ISO/NIST (next lectures) are **cybersecurity-specific** standards. A standard can still be used inside GRC.
- **COBIT vs COSO:** IT/ISACA community vs accounting/AAA community. COSO's keyword is **control**; COSO ERM's move is **risk** (assessment **plus** response).
- **Cyber as standalone vs cyber as one ERM risk:** GRC does the latter; standards-driven and small-firm practice often do the former.
- **Training vs education:** ISO/COBIT market courses vs this academic organizational-planning path.

Exam lines

- Wish for the best, prepare for the worst; Pasteur: fortune favors the prepared mind. Incidents (Marriott 500 million, Target, Air India) are growing.
- Three approaches: GRC/ERM, standards (ISO/NIST), textbook strategic + contingency planning.
- GRC frameworks: COBIT (ISACA, end-to-end IT control, Plan–Build–Run–Monitor), COSO (internal control), COSO ERM (adds response, objectives, identification).

- Internal controls: what they control (assets, records, reporting, efficiency, policy, law) and how (preventive / detective / corrective).
- RBI can force cyber as a C-level strategic function in banks; other sectors may have no such mandate.
- Risk in GRC is postponed: later sessions treat cyber-risk assessment and the **five** response options.

Lecture T09: Security Management and GRC — Part 02

Learning focus

- Know when **COSO / COSO ERM / COBIT** are the wrong grain (startup, mid-size) and when **cyber-specific standards** still matter.
- Trace **ISO 27000** from **BS 7799** through **ISO/IEC 17799:2005** to **ISO 27001** in **PDCA** form.
- Explain **Plan–Do–Check–Act** as ISO 27001's improvement cycle (and relate it to COBIT's Plan–Build–Run–Monitor).
- Contrast **ISO** (European, paid, not open) with **NIST** (US, open standards) as the instructor teaches the politics and the adoption puzzle.
- Recap the class reasons why the world is not "all NIST / all open source": **service/support** and **reputation**.
- Know that **iPremier** (Harvard, versions A/B/C, 2018 update) is the day's case; discussion of A continues in T10.

Key terms

Term	Meaning in this lecture
BS 7799	British Standard that originated ISO's cybersecurity management line
ISO/IEC 17799:2005	Large control catalogue (**133** possible controls) before the 27000 rename
ISO 27000 series	ISO family **for cybersecurity management** (>50 standards; verticals and horizontals)
ISO 27001	Basic standard in the family; **PDCA** format; keep the ISMS in an improvement cycle
ISO 27002	"Fundamental" / control-guide standard; 27799 uses it for health
ISO 27799	Information security management **in health**
PDCA	Plan, Do, Check, Act — continual improvement cycle
NIST	US National Institute of Standards and Technology — open technology/cyber standards
Open standard	Freely accessible (NIST as taught here); opposite of paid ISO documents
iPremier	HBS e-commerce DDoS case, versions A/B/C

Frameworks / formulas

- **PDCA:** Plan → Do → Check → Act → (repeat). ISO 27001's shape; cousin of COBIT Plan–Build–Run–Monitor.
- **ISO 27000 map (as taught):** BS 7799 → ISO/IEC 17799:2005 (133 controls) → 27000 series (27001 PDCA core; 27002 guides; 27799 health; plus infrastructure, network, etc.).
- **Adoption choice:** GRC/ERM if large; cyber-specific ISO or NIST if the asset base is cyber / the firm is smaller; both can coexist.

Distinctions

- **COSO ERM / COBIT vs ISO/NIST:** enterprise GRC vs **cyber-specific** standards. Small/online firms may skip ERM; they may not skip ISO/NIST-type practice.
- **ISO vs NIST:** European vs US; **paid/closed vs open**. Preference follows regional politics and military/sensitive-use history, not only technical merit.
- **Having a standard ≠ implementing it.** Open documents still need expertise; free software still needs **service**.
- **Product vs service:** you consume service; that is why proprietary stacks persist.
- **This hour is industry familiarization**, not a full ISO/NIST implementation course. Contingency-planning procedure is deferred to NIST + later lectures.

Exam lines

- Large-firm GRC is optional for a startup; **cyber-asset standards are not optional** if you are online / IT-heavy.
- ISO 27000 = ISO's cyber management family, from **BS 7799**, through **17799:2005 (133 controls)**, to **27001 (PDCA)**.
- PDCA keeps the security system in a live improvement cycle.
- NIST standards are **open** (e.g. computer security handbook); ISO's 27000 documents are **not**. Class reasons ISO still wins: **support** and **reputation**.
- iPremier A is the case vehicle for "what happens when an e-commerce firm has no working GRC/standard/contingency practice."

Lecture T10: Security Management and GRC — Part 03

Learning focus

- Reconstruct the **iPremier** A narrative: who is who, 04:30 timeline, Qdata, missing IR/DR/BCP.
- Define **DoS vs DDoS**, botnets / zombie networks, and the **SYN flood** as used in the case.
- Separate **technical** failures from **managerial** failures (stock-option culture, no cyber strategy, no standards).
- State the **four stakeholder pressures** on CIO Bob Turley and why the instructor treats "resume as usual" as the riskier path.
- Carry the teaching verdict: an e-commerce firm that ignores GRC/ISO-type frameworks and **contingency planning** can go out of business; PR and time-to-restore

are part of the decision, not extras.

Key terms

Term	Meaning in this lecture
DDoS	Distributed denial of service — many systems flood a target so legitimate users cannot use it
DoS	Same aim, **single** source, smaller scale, easier to attribute
Botnet / zombie network	Malware-controlled machines the attacker uses to generate flood traffic
SYN flood	The DDoS form identified on iPremier's **firewall router**, from multiple sites
Qdata	Third-party host; proximity (and personal ties) over competence
BCP binder	Business continuity document they **have** but have **not updated or practiced**
Market Top	Main competitor; switching risk if iPremier goes dark
Catch-22 of the night	Diagnose (needs shutdown) vs survive in a niche online market (needs uptime)

Frameworks / formulas

- **GRC lesson applied:** e-commerce at this scale should have had a **framework or ISO-type standard** plus **IRP/DRP/BCP**. None were live.
- **Decision frame:** four voices (CEO, ops, stock/PR, legal) → one CIO call.
- **DoS ⊂ DDoS** as taught: DDoS is the distributed, multi-source form of DoS.

Distinctions

- This **was** a DDoS, not a "failed attempt." Unknown = whether **intrusion / data theft** rode along (DDoS ⇏ "no intrusion").
- **Technical right ≠ business right.** A long shutdown can **end the firm** in a two-player luxury e-commerce market.
- **Hiding vs disclosing:** later revelation (especially if the rival is the attacker) destroys **high-end trust** more than an honest hit now — but the **wording and duration** of any shutdown statement are the live problem.
- They were **at the attackers' mercy**; the attack **self-stopped**. Without diagnosis you cannot claim corrective/preventive action, so **resume as usual is the more dangerous** operational choice.
- **"How long?"** is the CEO question; "we don't know" is true and **unacceptable**. That is the case's dilemma, not a student failure.
- Preparedness fantasies (hot site, updated binder) are **not available options** at 05:26 if you never invested. The case shows what **lack of GRC + contingency** does to an online business.

Exam lines

- iPremier: luxury e-commerce, trust-critical, stock-option culture, Qdata, logging traded for 20% UX, BCP stale, no IR practice, Joanne locked out, SYN-flood DDoS,

attack stops itself.
- DoS vs DDoS; botnets/zombies; motives include rivalry and extortion.
- Failures: technical (Qdata, firewall, logs) **and** managerial (no cyber strategy, no framework, stock over risk).
- Bob must reconcile CEO uptime, ops shutdown, legal disconnect, and VP stock.
- Instructor: find out why it stopped; PR is part of the decision; B/C will show what happens if you do not shut down.

Lecture T11: Contingency Planning — Part 01

Learning focus

- Split cybersecurity planning into **organizational (preventive)** vs **contingency (reactive)** — different objectives.
- Use **iPremier** (and **IVK**, **Target**, **Saudi drone**) to show what "no plan" does to people and to **ROI arguments** for security spend.
- Align security plans with **strategic / tactical / operational** business plans (and correct the textbook's order).
- Classify incidents by **impact** into **IRP**, **DRP**, and **BCP**, including the site-shift rule for BCP.
- Trace the instructor's incident picture: **assets → vulnerabilities → exploit → incident → impact → contingency action**.

Key terms

Term	Meaning in this lecture
Contingency planning	Reactive: restore to normal **in minimum time** after an incident
Organizational planning	Preventive: strategic / tactical / operational plans that **protect**
IRP	Incident response plan — **low** impact; operations continue
DRP	Disaster recovery plan — **high** impact; restore **without** changing site
BCP	Business continuity plan — impact so high you **relocate**
IDS	Intrusion detection system — capital item finance wants ROI for
Vulnerability	Gap in walls/firewalls that can be exploited
Exploit	How a hacker uses a particular gap
Incident	Attack that **actually happened** (after intrusion)
Emotion-focused coping	Yelling / fleeing / wishing when there is no plan (Gilbert)

Frameworks / formulas

- **Preventive vs reactive** planning split.
- **Strategic (3–5 yr) → tactical → operational** (textbook order corrected).
- **Impact → IRP / DRP / BCP.**

- **Investment rationale for controls:** not new revenue; **cost avoided » spend**. Quantify legal, sales hit, downtime, recovery. Dynamic, not one-time. Proportional to risk (later module).
- **Incident chain:** assets → vulnerabilities → exploit → incident → impact class → plan type.

Distinctions

- **Contingency ≠ risk-management planning.** One is **after** the incident (restore); the other is **so the incident does not happen** (protect). Both are required.
- **IRP ≠ DRP ≠ BCP.** Same family, **different impact**. BCP is the one that **moves the organization off site**. DRP is severe but **same location**.
- **Textbook's planning-level order is wrong**; use time range: strategic, then tactical, then operational.
- Security spend is **cost reduction**, not a new revenue stream. Finance will not buy qualitative fear; IVK shows the **articulation** failure.
- **Doing nothing is not an option** even when numbers are soft (no mature cyber insurance).
- Protection (shoe knurls) does **not** mean zero incidents. Contingency exists **because** residual gaps remain.

Exam lines

- Contingency = reactive restore-at-earliest; organizational planning = preventive, aligned to business goals (Franklin; JFK "and back safely").
- No plan → emotion, blame, job-protection (iPremier, Gilbert).
- IVK: IDS has no classic ROI; quantify **avoided cost**; seniors must learn that.
- IRP / DRP / BCP chosen by **impact**; BCP = cannot operate here (Chennai floods).
- Incident = exploit of a vulnerability against an asset; then classify low/medium/high and act.

Lecture T12: Contingency Planning — Part 03

Learning focus

- Carry Part A into **B**: public disclosure, 75-minute DDoS, file-name checks that **do not** prove integrity, Ripley's 24–36 hour rebuild.
- Explain why **keeping the old site live while building a new one** is the business-friendly option and still **technically unsafe**.
- Follow **Part C**: no comprehensive shutdown → **FBI** call that iPremier is attacking **Market Top** from a production host → firewall **was** penetrated ("fire suppressed during the retreat").
- Use the instructor's corrections: do not compare **Google/Microsoft** competence with **Qdata**; a new site without **updated firewall/IDS** repeats the failure.
- List the team's mitigation map (CDN, scale, DDoS services, CPMT, IRP/DRP/BCP, CIA **availability**) without treating it as a substitute for the case's **catch-22**.

Key terms

Term	Meaning in this lecture
File identity and size check	Proves names/sizes exist; **does not** prove contents or extra malware files
Development files	Build source treated as **less likely tampered** than production
“Fire suppressed during the retreat”	Apparent stop of the DDoS hiding a **planted** capability
Credit-card processing agreement	Separate lawsuit path if numbers were stolen
CDN	Distributes flood traffic so one origin is not the only choke point
Defence in depth	Different controls per layer (team’s Google 3–4 vs 6–7 reading)
CPMT (NIST 7-step)	Contingency committee the firm should have had **before** 04:30
Catch-22	Forensics need darkness; the market needs light

Frameworks / formulas

- **Reactive vs proactive** (B’s post-attack shopping list vs Google’s pre-built Armor).
- **IRP / DRP / BCP** restated by the team: during / after / parallel-run — matching T11–T13, applied to a firm that had none.
- **CIA:** availability first casualty (ops locked out of the host).
- **Cost vs time** on the rebuild decision (instructor: both, plus **technical viability**).

Distinctions

- **Presence of files ≠ integrity of files.** Without content verification you do **not** know there was no intrusion.
- **Option 2 is not “we will be ready next time.”** It is **running the unknown-bad production site until a future date.** Hackers do not wait on your project plan.
- **Shutdown needed for forensics** vs **shutdown as customer suicide** — the case does not dissolve that tension; Part C shows what “no shutdown” **became**.
- **Do not copy hyperscaler playbooks onto Qdata.** New site without **new firewall + IDS** is the same vulnerability with a new label.
- A parallel server **on the same stack** is not by itself a DDoS answer; **separating payment data** is the more serious architectural hint from the floor.

Exam lines

- B: public DDoS admission (75 min); name/size audits; Ripley 24–36 h rebuild vs live-old + new-site (~3 weeks); logging had been a 20% UX trade.

- C: they stay up; two weeks later FBI says iPremier is the attacker; planted file on production; Market Top and card-brand legal risk; rebuild now looks like evidence tampering.
- Theory applied: hot site, CPMT, IR/DR/BCP, simulated attacks — all **after** the fact.
- Instructor: diagnose the unknown; don't pretend Google's night is iPremier's night.

Lecture T13: Contingency Planning — Part 02

Learning focus

- Put a **CISO** (and RBI's separate security role) on the organizational-planning side, then switch to contingency.
- State the **goal of contingency planning** and the job of the **CPMT**.
- Run **business impact analysis (BIA)** on **business processes** (not assets), using **MTD, RTO, WRT, RPO**.
- Use the **cost-of-disruption vs cost-of-recovery** graph; name the intersection as the management negotiation for time.
- Switch **IRP → DRP → BCP** by impact and by **who leads**; keep **DR = same/primary site**, **BCP = change site**.
- Know IR **before / during / after**, Pipkin's indicators, **GDPR 72-hour** reporting, **hot/warm/cold** (and time-shared) sites, and **red/blue/purple** tests.

Key terms

Term	Meaning in this lecture
CISO	Chief information security officer; reports to CIO; policy, plans, budget, monitor, law, incident comms
CPMT	Contingency Plan Management Team/Committee — oversight of CP and subcommittees
BIA	Business impact analysis — process-level impact; sets the clocks
MTD	Maximum tolerable downtime — **process owner**
RTO	Time to **system live** — technical
WRT	Time to **operations** after the system is live
RPO	How far back you can recover — **backup policy**
Redundancy	Extra capacity (hot/warm site) that buys short MTD at high recovery cost
Hot / warm / cold site	Parallel-ready / make-ready-in-time / slowest alternate location
Pipkin indicators	Possible / probable / definite signs an incident has occurred
After-action review	Post-event: did the process improve or worsen?

Frameworks / formulas

- **MTD = RTO + WRT** (RPO separate, from backup cadence).

- **BIA unit = business process**; **risk unit = asset**.
- **Cost trade-off:** disruption cost ↑ with downtime; recovery cost ↑ as target downtime ↓; **optimum at intersection**.
- **IRP (tech) → DRP (CIO, same site) → BCP (CEO, new site)** by impact.
- IR: before / during / after; document what–when–where–why–how.
- GDPR: report in **72 hours**.
- Test with red / blue / purple.

Distinctions

- **CISO ≠ CIO.** Banks (RBI) must have both; CISO owns the security **policy/plan** track.
- **BIA ≠ risk assessment.** Processes vs assets.
- **MTD is not a tech number.** Process owner sets it; tech fits RTO+WRT inside it. **Zero MTD** is ideal and **unusable** without paying recovery cost.
- **Downtime cost ≠ restoration cost.** Fast restore requires **redundancy spend**. CP is **negotiation for time**.
- **DR vs BCP (site rule):** DR recovers **at the primary site**; BCP is when you **cannot stay** and **move**. Naming is awkward (BCP is a process name, not an event name).
- **Threat vs incident.** Threats are potential; incidents have happened; you still need logs/IDS to **know**.
- **Hide vs law:** GDPR removes the "contain it internally" option on the EU facts.

Exam lines

- CISO reports to CIO; writes policy/plans/budgets; RBI wants this role in banks.
- CPMT restores to normal **at minimum cost**; BIA on **processes** sets **MTD, RTO, WRT, RPO** with **MTD = RTO + WRT**.
- Draw the two cost curves; manage at the **intersection**; that is "earliest."
- IR → DR (same site, CIO) → BCP (relocate, CEO).
- Hot/warm/cold; Pipkin indicators; GDPR 72 hours; red/blue/purple to keep the binder from becoming iPremier's.

Lecture T14: Live session — Contingency planning Q&A

Learning focus

- Restate contingency as **planning for the unexpected**: CPMT restores to **normal operation in minimum time**.
- Hold both costs: **downtime vs restoration/redundancy**; optimum at the **intersection**.
- Use the instructor's **on-the-spot correction**: **DR = recover at the same location**; **BCP = you must relocate**.
- Distinguish **vishing** (malicious **voice** calls) from **phishing** (malicious **email**).
- Apply textbook roles: **data owner**, **data custodian**, **data user / subject**.
- Treat **technological and managerial vulnerabilities as intertwined** (Target LAN, iPremier logging, Equifax governance).

Key terms

Term	Meaning in this lecture
Management	Managing **resources** (people, money, land, materials, technology)
Contingency	Unpredictable incident; plan for the unexpected
CPMT	Team whose role is restore to normal **in minimum time**
Cost trade-off	Downtime cost vs restoration/redundancy cost; optimum at intersection
IR	Lower-impact incident (e.g. one machine)
DR	Recover from a severe event **at the same location**
BCP	**Cannot** operate here; **move out**
Phishing	Malicious **email**
Vishing	Malicious **voice call** (phone-channel phishing)
Data owner	Senior management; security/use; **classification**
Data custodian	Operational; systems that process/transmit/store (e.g. DBA)
Data user / subject	Person whose data is stored (students; privacy "subject")
People–process–technology	The IS breakup; all three carry vulnerability

Frameworks / formulas

- Planning vs no planning → **higher cost / inefficiency**.
- Contingency **reactive**; risk management **later / protective**.
- **Shorter downtime target ⇒ higher restoration cost** (redundancy).
- **DR same site / BCP relocate** (after the spoken correction).
- **People, process, technology**; managerial cause → technical symptom.

Distinctions

- **He misspoke, then corrected:** moving plant because the site is dead is **BCP, not DR**. **DR = same location.** Learn the correction, not the first sentence.
- **Zero downtime ≠ free.** You pay in **redundant systems**.
- **Phishing ≠ vishing.** Email vs **voice**.
- **Owner ≠ custodian ≠ user.** Senior classification vs operational DBA vs the person in the database. Do not use the words loosely.
- **Tech vulnerability vs managerial vulnerability:** often **one event with two layers** (LAN misconfig is what was exploited; **who configured it** is management). Logging off is a **decision**, not a mysterious technical fate.
- **Best technology ≠ no breach** (Target). Later, **governance** can fail too (Equifax).
- Contingency is required **even if** risk management and controls were done.

Exam lines

- Management = resources; planning cuts loss. Contingency = paradox of planning the unexpected; CPMT restores **earliest**, subject to the **two-cost** intersection.
- IR small; **DR same site**; **BCP relocate** (instructor's apology is the rule).
- Phones: malware and **vishing**; email **phishing**.

- Owners (senior, classify), custodians (operational systems), users/subjects (whose data).
- Target/iPremier: people and technology **together**; standards/processes are what reduce those errors.
